

Informe de Auditoría de Seguridad Informática

Preparado por: Luis Antonio Canales Guerrero

Referencia: Alineación con el Marco de Ciberseguridad del NIST
(NIST CSF)

1. Fase de Inventario y Clasificación (Identificación)

Se ha iniciado un proceso exhaustivo de conteo y organización de todos los activos tecnológicos para mitigar el riesgo derivado de la falta de gestión actual. Este proceso se divide en:

- Inventario General de Activos: Registro detallado de hardware presente en las instalaciones físicas, incluyendo dispositivos móviles de empleados bajo políticas BYOD (laptops, smartphones), estaciones de trabajo en ubicaciones remotas y periféricos esenciales.
- Segmentación y Clasificación: Se han categorizado los activos según su criticidad para la operación. Los sistemas identificados como vitales incluyen los servidores de contabilidad, infraestructuras de bases de datos, plataformas de comercio electrónico y sistemas de gestión de inventarios.

- Gestión de Sistemas Heredados (Legacy): Se detectaron infraestructuras tecnológicas antiguas que han superado su ciclo de vida útil. Al no contar con soporte o actualizaciones, se ha determinado que requieren un monitoreo humano ininterrumpido para prevenir errores críticos o brechas de seguridad.

2. Plan de Protección y Continuidad del Negocio

Tras la fase de inventario, se determinó una puntuación de riesgo residual de 8/10, considerada como nivel Crítico. Para reducir esta métrica a niveles aceptables, se han diseñado las siguientes estrategias:

- Gestión de Identidades y Control de Acceso: Implementación del principio de Mínimo Privilegio (PoLP). Esto garantiza que el personal administrativo y técnico posea únicamente los permisos estrictamente necesarios para operar en sistemas críticos, configuraciones de firewalls y herramientas de monitoreo SIEM.
- Resiliencia y Recuperación: Desarrollo de un plan formal de contingencia y respaldo de datos. El objetivo es asegurar que, ante un desastre natural o un ciberataque, la empresa pueda recuperar su operatividad en el menor tiempo posible.
- Estandarización de Respuesta (Playbooks): Creación de Libros de Estrategia detallados. Estos documentos sirven como guías tácticas paso a paso para que el equipo de respuesta a incidentes actúe con precisión y rapidez ante cualquier intento de violación de seguridad.

3. Evaluación de Vulnerabilidades (Pentesting) y Hallazgos

Se ejecutó una fase de pruebas de penetración controladas para evaluar la eficacia de las defensas actuales:

- Auditoría de Controles Técnicos: Evaluación del desempeño de los firewalls y los Sistemas de Detección de Intrusos (IDS). Se verificó su capacidad para identificar, alertar y bloquear intentos de acceso no autorizados desde redes externas.
- Análisis de Cumplimiento Normativo: Verificación de los estándares de seguridad para el manejo de datos bancarios y tarjetas de crédito (PCI DSS), así como los protocolos de privacidad para datos de ciudadanos de la Unión Europea (GDPR).

* Diagnóstico de Riesgo Legal: El resultado de las pruebas confirma que la carencia actual de controles técnicos y administrativos genera una probabilidad elevada de pérdida de datos sensibles, lo que podría derivar en sanciones económicas y multas legales severas.

4. Conclusiones y Recomendaciones Estratégicas

1. Diagnóstico de Situación: La postura actual de ciberseguridad se define como de alto riesgo. La combinación de una gestión inadecuada de activos y el incumplimiento de normativas internacionales deja a la organización vulnerable.

2. Mitigación Inmediata: Es imperativo fortalecer los controles técnicos y, de manera paralela, formalizar las políticas de seguridad por escrito para que sean de cumplimiento obligatorio en toda la organización.
3. Fortalecimiento del Talento Humano: Se justifica la expansión del departamento de ciberseguridad mediante la contratación de personal especializado. Este equipo tendrá la misión prioritaria de supervisar constantemente los Sistemas Heredados (identificados como el eslabón más débil) y garantizar el mantenimiento preventivo de los nuevos controles establecidos.

Firma: _____

